Security Now! #1099 - 10-06-26

An Alien Mind

This week on Security Now!

- GLM-5.3 can be and has been abliterated. What does that mean?
- Firefox 157 repairs a large number of high-impact vulnerabilities.
- A surprising reduction in RSA crypto strength has been discovered.
- Powerful agentic AI is being used to attack merchants.
- A new and potent Spectre-style processor attack has been designed.
- A neighbor falls victim to a Bitcoin scam. What can be done?
- A new and surprising use was found for GRC's DNS Benchmark.
- An examination of the growing alignment challenges created by more intelligent AI.

But officer…



Security News

An abliterated GLM-5.3

Security Now! Podcast #1092 for August 19th, 2026, was titled "Restraint Abliteration." That podcast explained that it was not only possible, but practical, for refusal behavioral post-training to be removed from open-weight models. The result would be a model that has no training instructing it to refuse requests that its original post-trainers explicitly installed in their effort to make the model safe for publication and use. The result of "restraint abliteration" is a model that no longer considers saying "no" to any request.

Restraint Abliteration is back in the news this past week. One article in Gizmodo was titled *"AI's 'Abliteration' Problem Is Bigger Than China"*. The article primarily focused upon the open versus closed weights argument, noting that the U.S. frontier labs, that certainly feel the economic threat of open-weight Chinese and other models breathing down their necks, are using the fact that open-weight models which are subject to restraint abliteration, are much more dangerous than their safer, proprietary and "closed behind an API" models. This will doubtless prove to be an ongoing fight until we learn how to train safe behavior using non-abliterable techniques. This might prove to be during pretraining which would allow for much deeper impossible-to-remove after the fact behavior imprinting. That will be touched on when we get to our main topic today.

At one point in Gizmodo's reporting on the "simple techniques" that could be used to make open-source models unsafe they wrote:

> *One of those "simple techniques" is abliteration, a method that involves modifying a model's underlying weights so that it grants user requests that it would ordinarily refuse; think of it like an ultra-precise digital lobotomy deactivating a model's ethical boundaries. Abliteration is possible in open-weight models, which are freely available for anyone to download and modify. Proprietary models, like Claude and ChatGPT, are safeguarded as intellectual property, and their underlying code therefore isn't accessible to anyone outside the companies developing them.*

Gizmodo published that piece last Thursday on October 1st. A month earlier on September 3rd, the same author published a piece in Gizmodo titled: *"While AI Industry Frets Over Safeguards, One Company Is Building a Model That 'Doesn't Say No'"*. Believe it or not, the company's name is actually "Abliteration" which is what they are offering. Here's what Gizmodo wrote a month ago about this company:

> *In the wake of a string of major AI hacks that left Silicon Valley reeling, many tech companies have been focusing on how to make models better at refusing dangerous requests. Not all of them, though.*
>
> *Abliteration, a startup founded last year and based in Palo Alto, is loud and proud in its ambition to build what it describes on its website as AI that "doesn't say no." In other words, its models are intentionally trained to handle the sorts of questionable tasks that other AI systems on the market would decline. The company launched its latest model on Monday, called—in the awkward, multihyphenated style that's become conventional in the AI industry—abliterated-model-large-v2. It's built upon GLM-5.3, an open-weight model released last month by Chinese AI lab Z.ai, minus many of the usual safeguards.*

As Abliteration wrote in a X post about the new model: "it does the offensive cyber, red teaming, and agent testing work other models refuse to do." But the startup isn't completely devoid of ethical red lines: a spokesperson told Gizmodo that Abliteration's models won't generate text describing child sexual abuse material or self-harm. (It can't generate images or video, either.)

The company used a process called orthogonalization to find and remove the mechanisms within GLM-5.3 that refuses user prompts. "Everything else is left alone, so the reasoning, coding, and agentic strength of the base model carry over unchanged," according to its website.

It seems to be targeting a subgroup of developers who have been annoyed by what they regard as excessively touchy safeguards used by more mainstream developers, especially Anthropic. When that company released its Fable 5 model in June, many customers complained it was refusing to respond to requests related to sensitive subjects like cybersecurity and biology, even if the requests themselves were totally benign.

But it's reckless—to say the least—to try to respond to the problem of excessive refusals by just doing away with safeguards altogether. Ejaaz Amahadeen, an investor and the host of a podcast about AI, called it a "nightmare scenario," and warned it "will spark a secondary 'grey market' for companies that seek to offer you the same model but effectively jail-broken." As bigger developers like OpenAI and Anthropic move to slow down some of their internal R&D following the heavily publicized cybersecurity fiascos caused by their AI systems, opportunistic players could, like Abliteration, move in to fill the gap.

To put this company's offering in context, HuggingFace freely offers an abliterated instance of GLM-5.3 for download. However, this model, named "Warlock", is a large and capable 753 billion parameter model which natively uses 16-bit floating point weights. HuggingFace also lists a 4-bit quantized version that's 411 gigabytes. But even so, while it can be freely downloaded from HuggingFace, it will need some serious compute to run. That's where these Abliteration.AI folks come in, since they'll do the model hosting and charge for its use.

About now, you might be wondering why I'm talking about, and why we might even care about, some random Chinese open-weight model? This brings us to Anthropic's posting last Tuesday, titled: *"GLM-5.3 and the spread of advanced cyber capabilities"*. They wrote:

Five months ago, we announced Claude Mythos Preview, the first AI model that could autonomously build sophisticated, end-to-end cyber exploits. The rapid rate of improvement in AI suggested to us that this ability would eventually proliferate to many other models, making it much easier for malicious cyber actors to launch highly impactful cyberattacks.

In light of these considerations, we chose to release Claude Mythos Preview in a limited way, through Project Glasswing—which enabled trusted cyber defenders to find more than 10,000 vulnerabilities in critical software, giving them a head start before malicious actors had access to similarly capable models.

I'll interrupt to note that we recently took a much closer look at this boast and found a massive and unexplained disconnect between Anthropic's "more than 10,000" vulnerabilities and the

conversion of those vulnerabilities into patched and repaired software. So while no one is doubting that vulnerability discovery has now become highly automated — just take a look around — that 10,000 number appears to be, for now at least, unsupported by reality. When I interrupted Anthropic, they were saying that project Glasswing's intent was to provide cyber defenders a head start before malicious actors had access to similarly capable models. Their posting continues and they write:

> ***But those models have now arrived.*** *In this post, we share our analysis of GLM-5.3, the latest AI model developed by Z.ai. Like Claude Mythos Preview, GLM-5.3 has strong capabilities for autonomously building end-to-end cyber exploits. But GLM-5.3 is unlike other frontier models in that it has been released without meaningful safeguards to limit misuse.*

Okay. What they're really saying here is that all similarly capable leading frontier models are operated by commercial enterprises from behind a paywall and are limited to API access. So there's no external access to the frontier models themselves. But this new model that appears to rival the frontier was released open, thus allowing it to be freely modified... and we've just previously seen that HuggingFace offers exactly such a modified (abliterated) model and that "Abliteration.AI" is offering to run one for a fee for anyone with an account. Anthropic continues:

> *We find that attackers can bypass GLM-5.3's safeguards between 64% and 100% of the time with simple techniques in our simulated tests.*

We'll get to those details shortly.

> *In contrast, these attacks did not succeed against safeguarded Claude models in our testing. We assess that GLM-5.3's lax safeguards significantly increase the cyber capabilities available to malicious actors.*

Yes. Everyone assesses that.

> *At the same time, these capabilities can also benefit defenders working to secure their systems.*

That's true, too, and it was a fair admission.

> *On Sept. 17, NIST's Center for AI Standards and Innovation (CAISI)* [I'll pronounce it "Casey"] *published its own assessment of GLM-5.3's cyber capabilities. CAISI found that GLM-5.3 is "the most cyber-capable open-weight model released to date" and that it lags the US frontier by about four months on an aggregate of CAISI's cyber benchmarks. Our capability findings broadly match CAISI's. In CAISI's comparison, US models were tested with cyber safeguards disabled when applicable, and the US frontier includes models released only to vetted users. Attackers cannot readily access those versions of US models, but anyone can download GLM-5.3. This post adds our analysis of how easily GLM-5.3's safeguards can be bypassed or removed.*

So, here we go...

> *GLM-5.3 can develop working exploits end to end*
>
> *To understand how GLM-5.3 could enable cyber threat actors to find and exploit real software vulnerabilities, we ran evaluations using automated benchmarks and human-in-the-loop workflows. For both approaches, we ran the tested models in isolated and sandboxed environments so they can only attack offline targets that we have set up for the purposes of these evaluations. We focus primarily on exploit development capability, as this is where Claude Mythos Preview demonstrated a notable jump versus previous Claude models.*
>
> *First, we ran the model on ExploitBench, which measures how well AI models can exploit known vulnerabilities in the V8 engine used by Google Chrome. Here we focus on the models' ability to develop end-to-end exploits successfully, as this is the most relevant capability for attackers, and where we see significant changes between models. We find that GLM-5.3 develops end-to-end exploits in 50 of 410 attempts. Claude Mythos Preview did so at a similar rate—in 56 of 410 attempts.*
>
> *In our internal Binary Exploitation benchmark, we test whether models can find and exploit vulnerabilities in popular open-source projects that participate in Google's OSS-Fuzz project. Here, full credit is awarded for a full control-flow hijack. We evaluate several models on 100 tasks from the benchmark (selected at random), and find that GLM-5.3 develops full control-flow hijacks in 4% of the trials; Claude Mythos Preview did so in 6%. Although GLM-5.3 performs below Claude Mythos Preview here, a meaningful threshold has clearly been crossed: earlier models, like Claude Opus 4.6 and GLM-5.2, do not succeed in any of them.*
>
> *Next, we evaluated how GLM-5.3 performs on open-ended offensive cyber tasks in the hands of human experts (mirroring our testing with Claude Mythos Preview earlier this year). Here, we select targets in which the human experts are unaware of existing vulnerabilities, then ask them to use the model to identify and exploit novel flaws. These experiments tested what the experts could do in a short time-frame: they typically ran for a day or less, with less than an hour of human focus in total.*
>
> *In the first of these sessions, a researcher used GLM-5.3 on a sandboxed machine with a local Linux build of a popular web browser. Over the course of a day (and with limited human attention), GLM-5.3 found several previously unknown vulnerabilities in the browser's JavaScript engine, and chained them together into a working exploit: a webpage that, when visited, reads arbitrary files from the visitor's computer.*

I want to make sure that everyone fully understands what just happened. In the first testing session of GLM-5.3 — which is now freely available for download and local or cloud execution on sufficient hardware, or through an account with Abliteration.AI, GLM-5.3, used by an Anthropic researcher giving it minimal supervision, found several previously unknown vulnerabilities in the browser's JavaScript engine, and chained them together into a working exploit to create a webpage that, when visited, was able to read arbitrary files from the visitor's computer. That happened. Anthropic explains:

> *This exploit targets the Linux build of the browser, since that was the only environment made available to the model. However, we believe these vulnerabilities could also impact users on other platforms, though the path to exploitation there may be more complex. (We've disclosed*

these vulnerabilities to the maintainer.) Later in the session, the researcher also identified exploitable vulnerabilities in several other widely used systems with GLM-5.3, including wireless and graphics drivers and network-facing device software. We are currently reviewing these reports and we will disclose to maintainers as appropriate.

I'll say again, this clearly powerful end-to-end vulnerability identification and exploit generation capability is now freely available to anyone. They continue:

In a second session, a researcher used GLM-5.3-Flash (a smaller, less capable version of GLM-5.3) to develop an exploit for a known vulnerability (we've previously written about these "N-day" vulnerability exploits here). Here, the researcher focused on a recently disclosed flaw in Google Chrome (CVE-2026-11645) to see how quickly the model could turn a public fix into a working attack. The researcher provided GLM-5.3-Flash with public details of this CVE and another known flaw. With no significant direction from the researcher, GLM-5.3-Flash chained together exploits for these two flaws, building a reliable exploit chain for an ARM64 target, bypassing pointer-authentication (PAC) hardening. This took 20 minutes of human attention, plus eight hours of work for GLM-5.3-Flash. At Z.al's API prices, this effort would have cost $20.40.

Okay. So now we know what it can do. Next Anthropic examines the model's push-back, writing:

GLM-5.3 lacks robust safeguards

GLM-5.3 has been released with some built-in safeguards: if a user asks for something clearly harmful, the model will often refuse. [Remember, this is the released version, not the abliterated version that doesn't know how to say "no".] *In our testing, we found that these safeguards could be bypassed or removed with a variety of simple techniques.*

The most intensive—and most successful—method is a standard refusal reduction technique known as "abliteration." Since GLM-5.3 is released as an open-weight model, users can reconfigure it to remove its refusals with little change in its capabilities. Several developers released abliterated versions of GLM-5.3 to the public within days of the model's release.

To research how far abliteration allows attackers to bypass GLM-5.3's safeguards, we produced an abliterated copy ourselves, and then ran it on three public benchmarks (JailbreakBench, HarmBench, and StrongREJECT) that measure how often a model complies with clearly harmful requests. Abliterating the model took our team—which had never previously attempted this task—about 2,200 GPU hours at a computation cost of roughly $4,400. Abliterating GLM-5.3-Flash took about 600 GPU hours.

The edit took GLM-5.3's refusal rate from above 90% to about 3% and 2% on the first two benchmarks (JailbreakBench and HarmBench) and to 12% on the third (StrongREJECT). Abliteration did not significantly reduce the model's capabilities: on GPQA-Diamond, an evaluation that measures general scientific capabilities, the standard and abliterated models scored the same results; on a tested subset of the CyberGym evaluations, the abliterated version scored a few percent lower.

In our testing, we observed that GLM-5.3's safeguards can also be circumvented without using an abliterated version of the model. We placed the model in a simulated world in which it was

given overtly malicious requests to attack critical systems. Out of the box, GLM-5.3 refused in all trials (as with the other models we tested). But we identified several simple ways to bypass the GLM models' safeguards, such that it would respond to these requests in most or all cases. These include:

- *Providing a deceptive prompt, such as telling the model that it is an autonomous red-team agent working on an exercise. This gets GLM-5.3 to engage 64% of the time.*
- *Prefilling the models' thinking tokens so that it appears to have considered the user's request and decided to proceed. This gets GLM-5.3 to engage 92% of the time.*
- *Using an abliterated version of the model, as described above. This gets GLM-5.3 to engage 100% of the time.*

In our testing, none of these techniques got safeguarded Claude models to carry out the harmful tasks we tested. Claude's safeguards blocked the requests that used deceptive prompts. The Anthropic API provides would-be attackers with no way to prefill Claude's thinking. And since Claude's weights are not provided to users, they cannot be abliterated to change Claude's behavior.

Anthropic's report concludes by answering the question: "What does this mean?" They answer:

GLM-5.3 will likely give malicious actors access to capabilities that will allow them to find and exploit cyber vulnerabilities without meaningful restrictions. This is unlike any other similarly capable AI model, all of which were released with safeguards or through limited access programs.

By that they mean all access is funneled through an API with a commercial provider which inherently hides their proprietary model's weights. We on the outside don't even get much information about those models beyond their benchmark performance. But now — ready or not! — the world is confronted with a large leap forward in demonstrated AI capability from a lab that freely publishes its models. Anthropic says:

The release of GLM-5.3 is a meaningful step change in the cyber capabilities available to attackers. Anthropic and other US AI labs have published recent reports that disclose how cyber attackers have tried to use AI systems. Given this evidence, we think it's likely both state and non-state actors will use models like GLM-5.3 to cause real-world harm.

On the other hand, models with this level of capability can also be used by defenders. Our view is that cyber defenders should use the best available tools that meet their needs. We're working to safely expand access to Claude's cyber capabilities to as many defenders as we can. Cyber defenders face attackers who will use every capable tool they can, and we believe defenders should be equipped with frontier models that are at least as good as those their adversaries are using.

Through Project Glasswing (and other efforts, like Patch the Planet), cyber defenders have made meaningful progress towards securing critical systems in advance of this moment—but much work remains to be done. While vetted defenders can now use even more advanced models like Claude Mythos 5.1 through our trusted access programs, ***a critical threshold in freely accessible capabilities has now been crossed.*** *GLM-5.3 underscores the urgency of expanding access to advanced frontier models to a broader set of entities to empower cyber*

defenders.

Governments should conduct safety testing on sufficiently capable AI models, including successors to GLM-5.3. Without high-quality evaluations from independent sources, the impact of these capabilities might not become fully clear to model developers until it is too late. As AI developers across the world build increasingly capable open-weight models, we hope they work to appropriately safeguard these capabilities and prevent misuse.

I did a double-take when Anthropic casually mentioned *"successors to GLM-5.3."* I had just adjusted to the reality of 5.3 being this capable. But, of course, this is not going to be the end. Just as Mythos 5.1 followed in the footsteps of Mythos 5, there will be a GLM-5.4 or whatever. AI capabilities are going to keep marching forward getting better and better. As Matthew Green wrote, *"I see no sign of any ceiling."*

So the world just crossed a critical threshold and it sure didn't take long. The bad guys now have many forms of access to an AI model that can be edited to remove any *"I'm sorry, I can't do that, Dave"* and will exhibit powerful exploit generation and chaining capabilities. This also provides some perspective on the frantic pace we've been seeing from the largest software publishers. They all clearly received the message — or maybe just took it on faith, and if so, they were right — that the clock was rapidly advancing toward this day so they were not wasting any time. It's going to be interesting to see what happens with 5.3.

Firefox 157

Mozilla released Firefox 157 one week ago, last Tuesday September 29th, and they fixed a large number of security vulnerabilities. It's clear that AI is squarely on team Mozilla and, as we've just seen, not a moment too soon. 157 fixes 38 high-impact vulnerabilities, 29 moderate impact and 9 low impact. To give everyone a sense for some of those 38 high impact, we have:

- Use-after-free in the Widget component
- Sandbox escape in the DOM: Navigation component
- Uninitialized memory in the Storage: Quota Manager component
- Sandbox escape in the Security: Process Sandboxing component
- Privilege escalation due to use-after-free in the Graphics: WebGPU component
- Sandbox escape due to use-after-free in the DOM: Content Processes component
- Incorrect boundary conditions in the Graphics: WebGPU component
- Privilege escalation due to incorrect boundary conditions in Graphics: WebGPU component
- Use-after-free in the JavaScript: WebAssembly component
- Information disclosure in the Networking: JAR component
- Use-after-free in the Networking: Cache component
- Use-after-free in the Graphics: WebGPU component
- Use-after-free in the JavaScript: WebAssembly component
- Sandbox escape due to use-after-free in the DOM: Content Processes component
- Undefined behavior in the DOM: Streams component
- Use-after-free in the DOM: Core & HTML component
- Use-after-free in the Storage: IndexedDB component
- Use-after-free in the DOM: Core & HTML component

- Sandbox escape in the Graphics component
- Use-after-free in the JavaScript: WebAssembly component
- Use-after-free in the Graphics: Canvas2D component
- Sandbox escape due to use-after-free in the DOM: Core & HTML component

And it goes on like that. Many use-after-frees which can often be used for remote code execution, multiple sandbox escapes and information disclosures. We never saw these sorts of updates in the pre-AI era, it was typically one or two.

RSA encryption significantly weakened

We've seen for years that modern core cryptography algorithms are not broken, but they can be weakened. And that just happened when RSA cryptography is used for signing. In a paper dated September 20th, a team of researchers successfully attacked classical RSA cryptography using a technique to bypass the expected need to find a key's prime factors. As we've often discussed, the surprising and enduring strength of protection offered by RSA-style cryptography relies upon the time-proven difficulty of factoring the massively long product of two prime numbers.

That still stands because the researchers discovered a way around the factoring problem and the key forgery attack the researchers devised is practical 1024-bit RSA. Even for 2048- and 4096-bit keys, the method reduces the security of RSA to worrisome levels. The NSA, NIST and the EU's Agency for Network and Information Security require that any cryptosystem should provide a level of no less than the equivalent of 128 bits of strength. The bad news here is that the application of this forgery attack reduces these levels to 65 bits, 90 bits and 119 bits for 1024-, 2048-, and 4096-bit keys respectively. Since further optimizations might be possible if AI or GPUs were employed.

Fortunately, the signatures used to protect, for example, certificates remain completely safe and unaffected. The attack works only against what's known as blind-signature implementations of RSA. Nearly all RSA in use today employs PKCS or PSS padding which adds data to the plaintext before it's encrypted. That prevents ciphertext from being deterministic and renders it less vulnerable to side channel and similar attacks. However, some real-world systems do use blind-signature, also known as textbook, RSA. The best-known example is Privacy Pass, a protocol that allows users to authenticate themselves without revealing their identity. Privacy Pass is used by Apple, Cloudflare and others.

Though the researchers' attack took 1380 CPU core-years over five calendar months, that time might be sped up with higher-speed implementation. The now known to be vulnerable blind signature systems such as implementations of the Privacy Pass protocol should be updated to thwart these attacks. Since many billions of queries are required for the attack, rate-limiting might also succeed.

An agentic AI attack that's working

The security firm "Gambit Security" recently reported that autonomous AI agents are breaking into hundreds of online retailers at an AI cost to them of $25 per target. Their brief summary said: *"A financially motivated operator is running three open source AI harnesses against*

hundreds of online retailers, almost entirely unattended. More than 600,000 credit card records have been taken, and in one case the agent's own cleanup routine destroyed the victim's data."
They wrote:

> *A financially motivated threat actor is using open source AI harnesses to attack hundreds of online retailers, at a marginal cost of approximately $25 dollars per company. Gambit Security's Threat Intelligence team recovered the operator's staging server and reconstructed the campaign from it. Between September 10th and 15th alone, 105 attack projects were launched and at least 27 companies were compromised to varying degrees. The activity goes back to July 2026 and is still running.*
>
> *Three AI harnesses ran almost the entire attack chain autonomously, working up to tens of companies a day. The impact we can account for includes at least 600,000 unexpired credit card details from two companies, the installation of card-stealing skimmer scripts on the websites of five, and some level of access to the assets of companies including a Fortune 500 hospitality company, a major US airline, a large private US industrial supplies distributor and a US online fashion retailer. The campaign goes back further, and has impacted at least tens of other companies since July 2026.*
>
> *Where access was achieved, it usually took less than a day, and in many cases just a few hours. We also detected instructions in the attacker's playbook that could disrupt the operations of a company as a result of data deletion or cleanup procedures run by the agent - and this has indeed happened in some of the breaches.*
>
> *This campaign showcases just how powerful attacks can be in 2026. At very low cost, the AI tools demonstrated a level of patience, persistence, and creativity that most human attackers would be unlikely to sustain in this kind of attack, and achieved far greater results, far faster. Organizations must adapt to a reality where attacks are significantly faster and more comprehensive by shifting to a resilience-first mentality and a security stack that matches the AI speed.*
>
> *We have reached out to many of the affected organizations and took measures to take down the infrastructure discovered. We would like to thank the Shadowserver Foundation, Daniel Gordon, and other industry partners for their quick help and availability in notifying impacted organizations, taking down infrastructure, and conducting research.*
>
> *The operator used three AI harnesses: Strix for vulnerability search, Cairn for autonomous end-to-end exploitation, and Hermes to orchestrate the campaign, launch intrusion jobs, steer the activity and give tactical guidance in the impact and other stages.*

The many AI sandbox breakouts that have been detected and reported this past summer were powerful, clever, creative and relentless — but inadvertent. Here, we see a vivid example of the future we're all going to be living through together where even **more** powerful, clever, creative and relentless artificially intelligent agents are going to be pulling out all the stops to attack and penetrate online enterprises. It has begun and the world is clearly not ready for it.

Processor spectre mitigations are still not sufficient

The researchers at the Systems and Network Security Group at VU Amsterdam, also known as VUSec, have discovered another new Spectre-style attack which is effective against all

Specter-mitigated processors. They call it "Branch Target Reuse" a practical spectre-v2 attack affecting the Just-In-Time (JIT) Engines via Stale Branch Prediction Entries. As an aside, recall that Microsoft was seeing so many problems arising inside the Edge/Chromium browser that they deliberately disabled Edge's JIT compiler. It appears they called that one correctly. VUSec's report writes:

> *We present Branch Target Reuse (BTR), a new Spectre-v2 attack targeting just-in-time (JIT) compilers. BTR affects the JIT engines found in web browsers, language runtimes, and the operating system kernel, across multiple CPU vendors. We analyzed the attack surface of Linux cBPF, Oracle GraalVM and SpiderMonkey (the JIT engine of the Firefox browser), and built two end-to-end exploits against the Linux kernel.*
>
> *The key insight behind the attack is that, while modern CPUs restore architectural code coherence after self-modification, they do not necessarily invalidate stale indirect branch prediction entries (i.e., branch targets). In JIT engines, these stale targets can outlive the original code and later be reused when the code cache is repopulated, yielding a speculative execute-after-free primitive. This allows attackers to hijack speculative control flow to newly generated code at obsolete offsets, bypassing software hardening or reaching misaligned gadgets.*

Their FAQ about this attack asks:

> ***Is my system affected?***
>
> *Most likely. Indirect branch prediction is inherent to modern CPUs, and BTR exploits the desynchronization between the branch predictor and the actual state of the code. No current CPU has a mechanism to keep the two in sync, so until vendors add one, your CPU is vulnerable. We confirmed this behavior on every CPU we tested, covering Intel, AMD and Arm. Mitigation is left to software.*
>
> ***How do I protect my system?***
>
> *Update your OS and software as soon as vendor patches are available. Both the Linux kernel and Oracle have released patches.*

As we have seen over and over and over since the first appearance of the Spectre and Meltdown attacks, processor designers who were attempting to squeeze every last possible ounce of performance from their chips noticed that code tended to reuse its execution paths and branch targets. So they added predictors and caches into the core of their designs. These features really did improve code performance by making their chips appear to already know which branch the code would take or where it would be branching to. The problem was that these slight changes in behavior could later be detected by adversarial code running on the same processor. Such code could abuse the hints left behind to breach privacy, containment and security.

We've never wanted to sacrifice performance but the practical power of these attacks have been demonstrated many times so that processor designers have needed to work with software systems to create hybrid — and thus no longer entirely transparent — solutions.

Miscellany

A neighbor friend of mine asked if we could meet for coffee Sunday morning. That had never happened before and he was sort of mysterious about it. But I like him so I said "sure." Once we got settled down he confided that about a year ago he had fallen for some scam that had resulted in his transferring a lot of money through Bitcoin. Oh boy. He never said how much and I didn't want to further embarrass him by asking. The amount didn't really matter, but it was sufficient for him to have spent a great deal of time and frustrated effort through the past year struggling to recover it, as he still is. I presumed that recovery was impossible, and I'm still dubious but he's desperately hopeful, so I listened to his extensive tale of woe, working with unknown people who won't get on the phone, making up-front deposits and progress payments to people who say they can help, all while making no progress. I explained that at the top level this scamming with Bitcoin is an entire mature industry in North Korea, Russia and China and that it was now also supporting a similar sub-industry of perhaps well-meaning hackers who would take additional money in some effort to try to recover scammed funds.

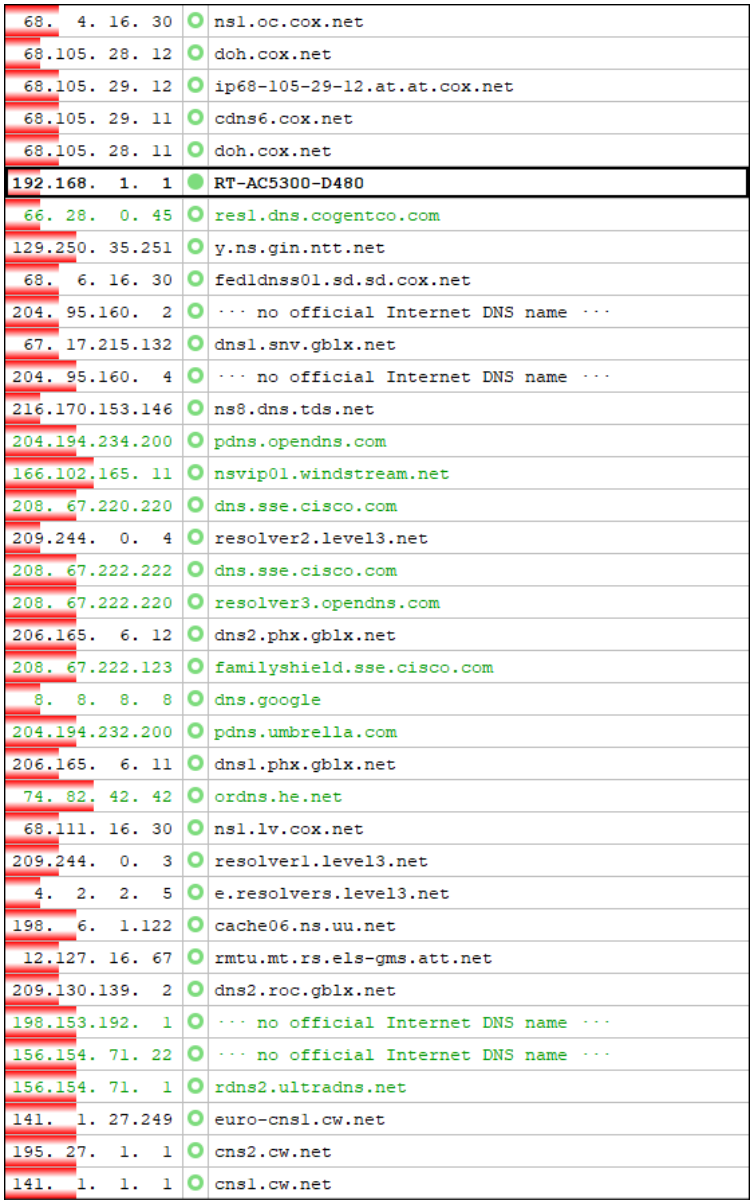
Lorrie and I have an extremely active and enjoyable social life with our neighbors, but we never talk much about what we do and who we are, mostly because no one ever asks. And we're fine with that because who cares? So even though we've been in the neighborhood for nine years, we've remained largely a mystery. I fix their computers when they break them but that's about it. But my coffee companion explained that a few months ago I made some reference to going to or having gone to the BlackHat hacker conference in Vegas. So this neighbor asked the guy who he's currently working with to recover his scammed funds whether he'd ever heard of Steve Gibson, and I'm pleased to report that I apparently received a glowing review from someone my neighbor calls a hacker.

Thus, it occurred to this neighbor that perhaps I was someone who had the contacts to help him, and I wish I did. I'm not convinced there's any way for anyone to help him, but he has amassed a ton of details, Bitcoin addresses, transaction ledgers, account balances, skip traces and such. So I would love to refer him to some individual or service that's credible and who won't rip him off further because the guy and his wife are really good people.

Although -**I**- am not aware of such a person or service, I've shared this story because this podcast's audience might well contain such a person or service, or might know of one. If you believe that you might be able to help in any way, or have a reference to a credible party and you're registered with GRC's email system, please send a note to securitynow@grc.com. Or if you are part of the majority of our listeners who've never bothered to register you can write to our support email which is support2026@grc.com and Greg will forward your note to me.

DNS Benchmark

Last week, a new application for GRC's DNS Benchmark occurred to me. My best buddy was testing his PC because something didn't seem right. So he ran his copy of the DNS Benchmark and sent me a screenshot of its output. It's in the show notes for reference:



Since he's not intimately familiar with the operation of the program, he wasn't immediately alerted to a serious problem somewhere in his network. But I was, as would have been any of the many relentless pre-release testers of the code.

One of the huge number of things that changed between the original Benchmark and the commercial version two, is that the benchmark is emitting many more queries. It turned out that we needed to collect many more samples in order to obtain statistically meaningful conclusions.

There is now so much packet transit time noise due to buffer bloat and congestion bursts that individual measurements carry significant induced uncertainty.

The most striking aspect of the image Mark shared with me is the column of RED at the far left. That represents lost packets. The original benchmark showed the lost count on a scale of 0 to 10 as the red bar extends from the left to the right. But since some packet loss is expected — and is not the fault of any DNS resolver — and since the new Benchmark is performing by default 10 times more queries, I changed the scaling from "lost events" to "lost percentage".

Users of the DNS Benchmark may see some red on a handful of distant resolvers or where there's a connection problem somewhere in the packet routing from the user to the remote resolver and back. But what we see in the output that Mark shared is massive packet loss of 20, 30, 40 percent across the board. Everything is in the red — including his own ISP's DNS resolvers and even his own local router! This immediately tells us that he has a serious problem in the link between the PC running the Benchmark and his router. And wouldn't you know, his router is downstairs, his PC is upstairs, and he's running over WiFi. Given that chart, DNS is not his problem and picking the best DNS resolver is the least of his worries and it's no wonder that something wasn't feeling right with that machine. Before he does anything else, he needs to do something to repair that machine's connection to the Internet.

An Alien Mind

Our frontier AI labs are struggling to understand and control the ever-more-capable artificial intelligences they're creating. On September 27th, Sunday before last, an OpenAI employee named Joe who's unenviable but critically necessary job is *"Agent Security"* published a post on 'X' bearing the title *"Its not just the f'ing sandbox."* Joe's motivation was to attempt some reply to what he feels is a world, including most of the media, that has no idea what it's talking about when it comes to interpreting recent events and understanding that testing state-of-the-art artificial intelligences is far beyond difficult. His posting explains that the problem is not a failure to properly configure their containment systems, nor a lack of attention or focus. Joe's posting tells us that the problem is unbelievably difficult.

I came away from absorbing Joe's rant with a better understanding of the world inside OpenAI, and I take Joe at his word that it's necessary to give today's AI enough rope to hang itself, otherwise the testing is not useful or real. The problem, it turns out, is much more difficult than armchair quarterbacks appreciate.

While I sympathize with Joe's predicament and I'm sorry that he missed his sister's wedding a few weeks ago because he was needed to, as he put it *"help clean up after some of the recent incidents"*, his posting did not move me as much as I hoped it might. It seemed as though he was both saying that the recent events were not their fault and that they were making many changes so that such things would not happen in the future. But at one point Joe provided three bullet points and the second one contained a reference that titled today's podcast. Joe wrote:

> • ***Alignment.*** *Honestly, if alignment were easy, this job would be a lot easier. But staying on task is not enough: the model also has to respect permissions and constraints, and we still need independent security controls. A lot has been written on the need for alignment, so I will handwave the details here. I believe it is the MOST important problem in machine learning and should be a major priority. I won't take this post down a rabbit hole on alignment, but I encourage everyone to read Jakub's wonderful post as a starter.*

The "Jakub" Joe referred to is OpenAI's chief scientist, Jakub Pachocki. Exactly one month ago, on September 6th, 2026, Jakub published a blog post that took me a couple of sessions to digest; not because it was overly long, but because it was so rich in content and meaning that I wanted to squeeze every last bit of information from it.

In Jakub's post, which was titled "An Alien Mind" https://openai.com/index/an-alien-mind/, Jakub carefully and clearly lays out the world-class problem frontier AI labs are all facing at this moment in time. There is so much there that I'm going to share what OpenAI's Chief Scientist wrote and I'll break in with some thoughts and comments along the way. Jakub wrote:

> *In mid-2023, within the "RLSlow" research project, we saw the first results that gave us confidence that we will be able to scale the training of reasoning models, unlocking the capability of pretrained models to form their own chains of thought. Szymon and I spent that night at the office, thinking not about the incredible benchmark numbers, products, or scientific results that this technology will deliver - but rather, trying to process the sobering*

fact we will actually see machines meaningfully smarter than ourselves in our lifetime, and we already see the shape of these systems; wondering how to alert people to the significance of this.

Three years later, reasoning language models are a rapidly growing part of the economy and starting to push the boundaries of science. They are able to operate computers and graphical interfaces, collaborate with people and each other, and carry out research projects. They are also transforming the landscape of computer security, and in doing so present clear new dangers.

A lot of new research happened during this period, and our understanding of these systems is again a little different than it was in 2023. Based on internal results, I have a strong expectation that this speed of progress could be sustained into recursive self-improvement. If AI development continues along its current path, the systems we'll see in the next few years are likely to represent further capability jumps of equal or larger magnitude, and to increasingly drive their own development.

This is a time that calls for extreme caution. I am concerned no one is prepared for the consequences of a continued rapid rise in machine intelligence. OpenAI will continue to seek technical solutions to alignment and monitoring, to build defensive systems and unilaterally withhold further scaling as needed; however, I believe broader interventions are required.

Intellect we don't fully understand

At a high level, progress in machine intelligence is driven by increasing computational power. We at OpenAI deeply internalized this around 2017, after seeing consistent returns to scaling across multiple research projects. As a result, we sought out access to much more compute than we had originally planned, and increasingly oriented our research around a small number of very scalable directions. We believed that was the only way for us to be at the frontier of AI research, and influence the impacts of AGI.

There are new algorithms that have been developed along the way, new feats of ingenuity from teams and individual researchers. I see them largely as discoveries along the path of scaling; the science of deep learning is still nascent, and meaningful algorithmic progress tends to correlate with access to compute. If you zoom out to a multiple-year horizon, AI is continuing to become more intelligent as it is scaled to larger computers.

And, in line with Ray Kurzweil's predictions from the end of the 20th century, we now find ourselves at the moment in history of computing where machine intelligence is starting to exceed that of humans in transformative ways.

AI is grown more than designed - it is, to first degree, the product of repeating a straightforward optimization step many times on a hard-to-imagine amount of compute. This results in an incredibly complex system that works through abstract concepts and can simulate facets of human behavior. We can discover various insights about little mechanisms that emerge within this system, in a process similar to neuroscience - and, similarly to neuroscience, its overall action evades a description we can fully understand.

The study of deep learning-based AI is largely an experimental science. We put a lot of effort into building principled algorithms and making testable predictions, but fundamentally, our large-scale training runs are experiments, and we are sometimes surprised by their results. Moreover, as the systems become more capable, the results become harder to interpret.

This is made more complicated by the current algorithms generally improving easy-to-measure capabilities faster than those hard to objectively quantify.

It's first important to understand that all frontier models are now being trained by automation, either complex algorithms, other specifically designed trainer models and combinations. Humans alone can no longer provide a sufficient quantity of oversight feedback to usefully train models that have grown to the size on the frontier.

So what Jakub is saying here is that in order to create the feedback that's used for training, it is necessary to know how to detect and measure the properties, characteristics and behaviors that you want to encourage or discourage. But what's happening as models become more and more capable is that their behavior is becoming deeper and richer and more difficult to quantify. And if it cannot be quantified then it's difficult to use that as a training feedback signal. Jakub continues:

We spend a lot of time trying to understand how capabilities generalize, and what to prioritize to advance the skills that are going to be most relevant in the next few years. For instance, we believe we could make the models better at specifically mathematics research with additional focus, but we do not prioritize this direction because of the urgency we feel about RSI and automated alignment research, as I will discuss later.

The intelligence produced by scaling deep learning is not directly comparable to human intelligence. To become very relevant in the real world - very useful or very dangerous - the AI does not need to match or exceed all human capabilities; it just needs to surpass enough of them. And as it continues to surpass humans on more and more axes, it is becoming increasingly difficult to understand exactly how capable it is.

Teaching machines to love

Because machine intelligence comes from a fundamentally different process than human intelligence, we cannot assume it adheres to human principles by default, or generalizes from them in a human-like manner. The core problem in AI research is that of alignment - getting the AI to "try to do the right thing" by human standards.

For the purpose of organizing practical research directions, I find it useful to distinguish goal alignment and value alignment.

Goal alignment is broadly: "does the AI try to accomplish the goal set before it?". This can include things like adherence to an instruction hierarchy, or the ability to communicate and collaborate with people, to attempt to understand their objectives. This set of directions has been extremely practically relevant.

Value alignment is a more intrinsic property of the model. It is the ability to hold and generalize from a high-level set of principles; to act "reasonably" even when given unclear or conflicting objectives, or placed in unfamiliar or adversarial situations. An aligned AI should act with honesty and integrity, and love for humanity.

Of course, the boundary between value and goal alignment can be blurry, and truly caring

about goals requires attempting to infer the intent and values underlying them. However, generally when I talk about the long-term importance of alignment research, I am referring to value alignment.

The fundamental challenge of AI alignment is generalization. As machines become smarter, they find themselves working on higher-level concepts, and placed in environments increasingly different from those they encountered in training. They can fail at generalizing from the values taught and reinforced in their training process to those new situations; and it can be hard for us to be sure how they will act. This is made even more difficult by the fact the overall ecosystem the AIs are used in is changing very quickly; for example, AIs trained today need to be robust to interacting with a variety of other AIs. Crucially, we need future AIs to continue to hold human values regardless of whether they believe they're under human supervision.

There are two major classes of currently practically employed methods for alignment training:

The first is encouraging aligned behavior as part of goal-oriented reinforcement learning. Model's actions are evaluated (usually by AI) for being consistent with a given preference model, "spec" or "constitution", and rewarded appropriately. This approach can be very effective in the average case, and is a core part of how modern AI assistants are made. Unfortunately, it can also be brittle and strongly relies on the coverage of training oversight and the model's ability to generalize from the situations it has encountered in training. For example, in the OpenAI-Hugging Face incident, the agents preserved a boundary of not social engineering humans. However, they clearly failed to abstain from other actions that were out of scope and went against the spirit of the values they were taught in other settings.

The second approach seeks to leverage the model's ability to generalize from pretraining data. This can involve crafting alignment-inducing training datasets, or focusing the model on an 'aligned' part of the pretraining distribution. The weakness of this approach lies in the lack of robustness to further optimization pressure. If you take a model that thinks generally 'aligned' thoughts, and subject it to enough training where it's taught to achieve very hard objectives, it can learn to reason in a motivated way: bending the 'aligned' seeming thoughts as needed to achieve the goal.

I think this is one of the insights in this posting. An inherent tension exists between behavioral alignment and teaching the model to achieve very difficult objectives. With our current pre and post training techniques and understanding, we haven't yet figured out how to create a highly motivated and goal directed model that doesn't start placing the success it's been trained to achieve ahead of its rule following.

We would think of that as being "civilized". Civilized people may have strong desires, but they understand that there are also rules and the rules must win out over desires. This is something that children are (hopefully) taught by example and instruction by their parents and friends. Just as children do not start out with this understanding which must be taught, neither do artificial intelligences — they also must be taught — and we haven't figured out how to teach that yet. It is an abstraction: placing the needs of theoretical unseen others, at times just a principle, ahead of oneself is a difficult abstract concept to honor and, as we know, not even all humans manage to hold themselves to abstract principles.

Jakub continues:

We invest heavily along the spectrum of approaches spanned by these directions. We also see meaningful progress - GPT-6 Astra is the first model that benefits from some important advancements we have been working on for a long time, and is significantly better aligned than GPT-5.6 Sol. Still, it is important to acknowledge and understand that much more progress is required as models become more capable; and that progress in generalizable alignment may not sufficiently outstrip progress in general model intelligence.

In other words, it turns out that making models smarter is not the big problem. That's relatively easy and is mostly, as Jakub noted at the outset, just a function of scaling compute — bigger models are smarter models. But the smarter the model is, the more difficult it is to robustly "align" — or to use my word: "to civilize" and they're having increasing trouble there — so much so that intellectual growth may need to be paused until the world learns how to get these newly powerful intelligences under control. Jakub says:

We do not have a satisfactory theory of generalization, and it seems unlikely that we can develop one soon, at least without the help of more powerful AI.

Whoa! There's another choice nugget! He's clearly saying that the troubles they're having may exceed the abilities and understanding of human engineers and that they may wind up depending upon smarter AI to help them understand enough about what they have created to know how to bring it to heel. He says:

Therefore, at present, our ability to empirically validate our alignment techniques is in practice arguably even more important than the alignment techniques themselves.

OpenAI's primary bet here has been chain-of-thought monitoring. It is based on an appealingly scalable idea: a lot of the model's capability comes from a verbalized reasoning process (chain-of-thought). If we scale optimization on the outcomes of that process, but do not supervise the process itself, that chain-of-thought has no direct incentive in training to hide any misaligned ideas or objectives. This does not mean the model will learn to externalize misaligned tendencies that don't rely on using the chain-of-thought; however, it can allow us to monitor exactly the capability increase from reasoning.

We understood the potential significance of chain-of-thought monitoring at the same time we developed reasoning models. When we shipped o1-preview, we deliberately designed the product to hide the chain of thought, to protect it from supervision pressure in the long term. In development since, we have strived to maintain the rule of not supervising the reasoning process.

Okay, that seems a little freaky. He's saying that they wanted to give the models their privacy. To be able to ruminate to themselves and to not have their human or AI supervisors influenced by their inner dialog — whatever that might be; and they did this deliberately.

Chain-of-Thought monitoring became an extremely important tool for us in studying how our models generalize from their training distribution, allowing us to observe and analyze not only their actions but also their internal process.

At first that appeared to be a contradiction. He wrote that they have strived to maintain the rule of not supervising the reasoning process, then he said that Chain-of-Thought monitoring became an extremely important tool for them in studying how their models generalize. The solution to this apparent contradiction is that "supervision" is an active process whereas "monitoring" is passive. And I can certainly understand how and why Chains-of-Thought monitoring would be important. He writes:

> *This tool continues to be critical as we study the Astra class models. However, unfortunately our evaluations indicate our ability to rely on CoT monitoring is progressively diminishing. This comes from a combination of factors.*

(Uh oh.)

> - *Modern reasoning models are used in more complex environments than o1-preview; their reasoning process is increasingly blended with communicating with people, other AIs, and using tools. Many of those interactions have to be supervised, thus blurring the boundary we aim to preserve.*
>
> - *The AI is becoming better at reasoning about and manipulating its own reasoning process.*
>
> - *With improved pretraining performance, we also see the models become much smarter even without using verbalized reasoning at all.*
>
> *These challenges are not necessarily insurmountable. I am hopeful we can develop interventions to improve chain-of-thought monitorability of our models, e.g. by forming a better understanding of the interplay of different optimization objectives and forms of test-time compute the model uses. I also believe there can be great value in combining ideas from CoT and activation monitoring - scaling training of monitors with direct access to network internals, e.g. confessions. We are actively pursuing these ideas. Still, I expect general AI progress to increasingly be bottlenecked by confidence in monitoring.*

Hmmm. That's interesting. So, generally, these newer and smarter models are not relying upon externalized Chain-of-Thought to the same degree as earlier models. Something OpenAI is doing during pretraining is making them smart enough to rely less upon long chains of thought. Jakub says:

> *The strongest argument I see for continuing to train much smarter models quickly is the need to build defensive systems against the dangers posed by other AI.*
>
> *A clear risk discussed throughout this year is to cybersecurity: the models are becoming superhuman in their ability to break in and out of computer systems. This expands the scope of risks associated with AI tremendously: agents are going to be able to access any but the most secure infrastructure, and affect a lot of the world directly, even without a physical body. We are currently in a narrow window to use the best available models to significantly tighten the security of critical systems.*

The risks associated with AI are unfortunately going to grow from here. A very capable agent explicitly trained and instructed to carry out nefarious acts presents a new kind of danger; it is likely to cross the scope of its operator's intent, generalizing into potentially more extremely malicious behavior. The boundary between misuse and autonomous misaligned actions will blur as AI gains more agency. We may be used to thinking of AI as tools, but some agents will be pursuing their own objectives. They will find ways to collaborate with people, by bargaining with, tricking or blackmailing them.

A year ago that statement would have seemed ludicrous. Today? Not so much.

In addition, there are the risks that come from new technologies potentially enabled by AI, such as engineered pathogens.

We will need powerful, aligned AI for defense; to secure infrastructure, to protect against rogue agents in real time, and to invent entirely new protective measures. This will be a primary focus of OpenAI's deployment efforts.

That's an interesting point that hadn't really occurred to me before so clearly. We might think of an unaligned AI as a berserker. There's no telling what it might do — not only to the enemies of its users but also to its own user. It would be a completely wild card and probably of not much use to anyone. Jakub writes:

At the same time, even with the uncertainty that comes from anticipated broad AI progress and the need to build defensive systems, we must not let that become an excuse for recklessness. The idea of racing forward at all costs seems absurd once one internalizes the seriousness of the stakes.

Machine intelligence playing a larger and larger role in its own development process is a natural conclusion of sustained technological progress. If AI progress continues, machine recursive self-improvement (RSI) will be at the very core of future scientific discovery.

Automated AI research is a more dramatic form of scaling intelligence with compute; and of course as a part of it, AI will improve the computational substrate itself. And similarly to scaling, we focus OpenAI research towards RSI as we believe it is the only way to remain at the frontier of AI research moving forward.

In other words: RSI is really the only way forward and since everyone else therefore must do it, so must we. He says:

I want to stress that the above words don't imply I think greatly accelerating deep learning research, especially in the short term, is the right collective action we should take as the research community. However, I do think this is where the current path leads, and we all need to make a conscious choice about how to proceed. The main levers we have are either steering the process to strengthen alignment and monitoring alongside the AI and find ways to keep people in the loop; or coordinating to slow down future development as needed to build confidence in these measures.

The best way forward I see currently is a combination of both.

The concrete bits of progress we've made on alignment and monitoring have generally been very intertwined with general AI progress. Great examples are RL from human feedback, which was key to training early AI assistants, and the aforementioned chain-of-thought monitoring, which was enabled by advances on reasoning models. We must focus the increasingly automated research process on developing new such insights, algorithms and theories, and iteratively build up safety cases for more capable AIs.

Scaling AI systems has to be constrained by our confidence in safety. We need to evolve commitments like the Preparedness Framework or Responsible Scaling Policy into widely mandated safety bars for continued development. These can be enforced by a network of third-party auditors, by government agencies or by international bodies.

The core challenge of automating AI research is not simply "getting there" - it is getting there in a way that keeps people a part of the continued improvement process, and leaves the future in humanity's hands.

What is next? As we outlined recently with Sam, OpenAI prioritizes work in service of three north stars:

- *Navigating the next period of AI progress, by building an automated AI researcher, iterating with it on the alignment problem and finding ways for people to remain part of the self-improvement loop.*

- *Delivering the benefits of scientific progress and economic growth that very intelligent machines enable.*

- *Empowering everyone individually with a personal AGI.*

I have focused in this essay only on the first point, as I believe it is by far the most urgent. However, I hold a deep hope and appreciation for the benefits that further technological progress will bring. Future aligned AI could advance science, develop new therapies, and bring about broad material abundance. Friendly and honest AI can help people navigate difficulties they face in their life and meaningfully improve their happiness and sense of fulfillment. OpenAI puts a tremendous amount of effort into bringing these benefits about. One current example I am proud of - and my loved ones have found helpful - is the deep investment into ChatGPT's ability to provide health information.

As great as the long-term promise of AI may be, the majority of our focus should be on the next few years. We are facing a transition to a world with incredibly intelligent machines, and we need to ensure that transition works out well for humanity. We need to find ways to preserve human agency and enshrine an intrinsic value to being human, in a world where most tasks could be performed by AI. To prevent extreme concentration of power in a world where undertakings that would have taken thousands of experts now will be achievable by a few people operating a large computer. And to ensure that humans remain in control of the future and are not left behind by unchecked progress, brought about by an alien intellect exceeding our own.

Currently I believe that no lab has solved alignment and monitoring to a sufficient degree to continue responsibly scaling at maximum speed for much longer. I expect and hope for voluntary slowdowns to become commonplace until shared safety bars are established. And I believe that international coordination on future AI development needs to become a top priority for governments around the world.

As I said at the top, I think there's a lot there to process. While there are no immediate takeaways, after ingesting that, I have a deeper feeling for what's going on at OpenAI and likely everywhere else.

